

Semana 6 — Objetivos de Aprendizado

Objetivos de Aprendizagem

OWASP Top 10

P: O que é o OWASP Top 10?

R: Um documento padrão de conscientização que lista os dez riscos de segurança mais críticos em aplicações web, atualizado periodicamente pela comunidade OWASP.

P: Por que injection é perigoso?

R: Ele permite que atacantes enviem dados maliciosos a um interpretador, potencialmente executando comandos não intencionais ou acessando dados não autorizados.

P: Como o XSS afeta aplicações web?

R: Ele permite que atacantes injetem scripts do lado do cliente em páginas visualizadas por outros usuários, possibilitando sequestro de sessão, desfiguração ou roubo de credenciais.

P: Qual é o risco da autenticação quebrada?

R: Ela permite que atacantes comprometam senhas, chaves ou tokens de sessão para assumir a identidade de outros usuários.

P: Você pode explicar a exposição de dados sensíveis?

R: Ocorre quando aplicações falham em proteger adequadamente dados sensíveis (como credenciais ou PII), expondo-os a acesso não autorizado por meio de criptografia fraca ou controles ausentes.

P: Descreva uma configuração incorreta de segurança.

R: Qualquer configuração padrão insegura, configuração incompleta, armazenamento em nuvem aberto ou recursos desnecessários mantidos habilitados — como contas de administrador padrão ou mensagens de erro detalhadas.

P: O que é XML External Entity (XXE)?

R: Um ataque que explora parsers XML mal configurados para revelar arquivos internos, executar requisições no lado do servidor ou causar negação de serviço.

P: Como os controles de acesso quebrados impactam a segurança?

R: Eles permitem que usuários ajam além de suas permissões previstas, acessando dados ou funções que não deveriam — frequentemente a falha mais prevalente e impactante.

P: Quais são as falhas de segurança mais comuns em aplicações web?

R: Injection, autenticação quebrada, XSS, controles de acesso quebrados, configurações incorretas, desserialização insegura e componentes vulneráveis estão entre os mais comuns.

P: Como prevenir a Desserialização Insegura?

R: Implemente verificações de integridade (como assinaturas digitais), imponha restrições rígidas de tipo e evite completamente desserializar dados de fontes não confiáveis.

P: Qual é a utilidade do logging e monitoramento de segurança?

R: Detectar, responder e investigar violações registrando atividades suspeitas e alertando sobre anomalias em tempo real.

P: Explique os riscos de usar componentes com vulnerabilidades conhecidas.

R: Atacantes podem explorar CVEs conhecidos em bibliotecas, frameworks ou dependências para comprometer a aplicação sem precisar criar novos exploits.

P: Como o uso de APIs pode aumentar os riscos de segurança?

R: APIs expandem a superfície de ataque ao expor endpoints adicionais, frequentemente com autenticação inconsistente, exposição excessiva de dados ou ausência de rate limiting.

P: Entenda o SSRF e os riscos modernos relacionados a APIs.

R: O SSRF permite que atacantes forcem um servidor a fazer requisições para recursos internos ou externos não intencionais, frequentemente contornando firewalls para acessar serviços internos.

P: Explique a importância do Logging e Monitoramento de Segurança.

R: Sem eles, as violações passam despercebidas por longos períodos — o logging fornece evidências forenses e o monitoramento permite resposta rápida a incidentes.

P: Identifique os riscos de Componentes Vulneráveis e Desatualizados.

R: Bibliotecas desatualizadas podem conter CVEs não corrigidos, carecer de suporte do fornecedor ou introduzir comprometimentos na cadeia de suprimentos que atacantes exploram ativamente.

P: Analise as falhas de segurança mais comuns em aplicações web.

R: A maioria decorre de validação de entrada insuficiente, aplicação precária de controle de acesso, mecanismos de autenticação fracos e falha em manter dependências atualizadas.

P: Entenda como as APIs modernas expandem a superfície de ataque.

R: APIs introduzem novos endpoints com modelos de autenticação variados, expõem a lógica de negócio e estruturas de dados subjacentes, e frequentemente herdaram a confiança do backend que atacantes podem abusar.

BurpSuite - Fundamentos

P: O que é o Burp Suite?

R: Uma plataforma integrada e abrangente para realizar testes de segurança em aplicações web, desenvolvida pela PortSwigger.

P: Como configurar um proxy no Burp Suite?

R: Configure as definições de proxy do seu navegador ou sistema para rotear o tráfego por 127.0.0.1 na porta 8080 (padrão) e instale o certificado CA do Burp para interceptar HTTPS.

P: Quais são os principais componentes do Burp Suite?

R: Proxy, Repeater, Intruder, Scanner (somente Pro), Decoder, Comparer e Extender, cada um com funções distintas em interceptação, manipulação, automação e análise.

P: Como o Spider funciona no Burp Suite?

R: Ele rastreia automaticamente o site alvo para descobrir conteúdo, funcionalidades e parâmetros ocultos seguindo links e analisando formulários.

P: Qual é a finalidade do Repeater no Burp Suite?

R: Modificar e reenviar manualmente requisições HTTP individuais repetidamente, observando como o servidor responde a diferentes payloads.

P: Como o Intruder pode ser usado em ataques?

R: Ele automatiza ataques personalizados como fuzzing, brute-force ou credential stuffing usando listas de payload, marcadores de posição e regras de grep-matching.

P: O que é o Burp Scanner e quando utilizá-lo?

R: Uma ferramenta automatizada de varredura de vulnerabilidades (disponível na versão Pro) que identifica problemas como SQLi, XSS e configurações incorretas durante avaliações ativas.

P: Como interpretar os resultados do Burp Suite?

R: Revise as descobertas categorizadas por severidade, examine os detalhes de requisição/resposta, valide falsos positivos manualmente e priorize com base na explorabilidade e impacto.

P: Quais são alguns problemas comuns que o Burp Suite pode identificar?

R: Falhas de injection (SQLi, command injection), XSS, autenticação quebrada, referências diretas a objetos inseguras, configurações incorretas de segurança e componentes vulneráveis.

P: Como configurar o Burp Suite para tráfego HTTPS?

R: Habilite SSL/TLS nas configurações de Proxy, navegue até qualquer site HTTPS usando o navegador configurado com o Burp e instale a Autoridade Certificadora do Burp para descriptografar o tráfego cifrado.

Descoberta de Conteúdo

P: O que é descoberta de conteúdo?

R: O processo de identificar recursos web ocultos ou não documentados, endpoints, diretórios e arquivos que não estão vinculados à navegação principal do site.

P: Por que a descoberta de conteúdo é importante?

R: Ela revela áreas da superfície de ataque que atacantes poderiam explorar — frequentemente contendo painéis de administração sem patches, arquivos de backup ou serviços mal configurados ignorados em auditorias padrão.

P: Como funciona o brute-force de diretórios?

R: Ele testa sistematicamente uma wordlist de nomes comuns de diretórios/arquivos contra um servidor alvo, verificando códigos de resposta HTTP para identificar recursos existentes.

P: O que é o Gobuster e como é utilizado?

R: Uma ferramenta de linha de comando rápida para brute-force de diretórios, subdomínios e hosts virtuais, iterando por wordlists e analisando respostas do servidor.

P: Explique o uso do Burp Suite na descoberta de conteúdo.

R: Os recursos de Spider e varredura passiva do Burp mapeiam automaticamente a estrutura do site, enquanto extensões como "Site Map" e Active Scan ajudam a descobrir caminhos ocultos.

P: Como o OWASP ZAP auxilia na descoberta de conteúdo?

R: Seu spider automatizado rastreia sites para encontrar todas as URLs acessíveis, e os módulos de varredura ativa investigam conteúdo oculto usando wordlists e heurísticas configuráveis.

P: O que são wordlists e como são usadas na descoberta de conteúdo?

R: Listas pré-compiladas de nomes comuns de arquivos/diretórios (como /admin, /backup) usadas para testar sistematicamente quais caminhos existem em um servidor alvo.

P: Descreva a finalidade de ferramentas como o DirBuster.

R: Ferramentas de enumeração de diretórios/arquivos com múltiplas threads, projetadas para realizar brute-force eficiente de caminhos web testando milhares de entradas de wordlist contra alvos.

P: O que são diretórios e arquivos ocultos em segurança web?

R: Recursos não vinculados publicamente, mas ainda acessíveis via URL direta — frequentemente interfaces de administração, backups de configuração ou arquivos de desenvolvedor expostos por controles de acesso inadequados.

P: Explique o fuzzing no contexto de segurança web.

R: Manipulação automatizada de entrada em que testadores enviam dados inesperados/payload a parâmetros para acionar erros, revelar vulnerabilidades ou descobrir endpoints não documentados.